

The Arzens

Governance, Risk & Compliance (GRC) Internship Project

Phase 4

ISO/IEC 27001:2022

Internal Audit Simulation

Corrective Action Recommendations for
Confirmed Minor Nonconformities



Usama Arshad

Governance, Risk & Compliance
(GRC) Internship

Lead: Shahal Farid

Co-Lead: Anas Zeeshan



Fictional Organization:
Kohsar Digital Bank (KDB)

Submission Date:
Monday, August 24, 2026

1. Purpose and Scope of This Document

This document offers corrective action recommendations for the six confirmed Minor Nonconformities detailed in the Phase 4 Nonconformity Report, which arose from the ISO/IEC 27001:2022 Internal Audit Simulation for Kohsar Digital Bank (KDB). Recommendations are based solely on the finalized Phase 3 Audit Evidence Log, Audit Findings Register, and the Phase 4 Nonconformity Report.

Root causes are stated only when directly supported by existing evidence; if the evidence does not establish a cause, this is clearly stated, and the matter is identified as requiring validation from KDB management rather than inferred explanations. Proposed corrective action owners are drawn from KDB's source documents. If the Statement of Applicability (SoA) and KDB's actual Task 9 policies assign different roles for the same control, this conflict is noted rather than resolved by assumption. No deadlines, thresholds, or SLAs are proposed beyond what KDB's source documents establish, as none are defined in the audit criteria for setting corrective action timeframes.

These recommendations apply solely to the six confirmed Minor Nonconformities and do not address or convert any Pending items or documented limitations recorded in the Findings Register into nonconformities.

2. Corrective Action Recommendations

NC-01 – Governance & Risk Escalation Flow, Stage 3 SLA

Confirmed Nonconformity Addressed: Two out of the eight sampled escalations breached the 3-business-day Stage 3 (GRC Co-Lead Review) SLA by 2 and 4 days, respectively, with no documented exceptions for either case.

Recommended Corrective Action: Conduct a formal review and document the circumstances surrounding the two identified SLA deviations, including whether the relevant exception process should have been followed at the time. Ensure that future Stage 3 SLA deviations are recorded through the appropriate exception mechanism at the time they occur, rather than being identified only through subsequent audit sampling.

Root Cause / Contributing Factor: Not established by the available evidence. The evidence confirms that two deviations occurred without a recorded exception; it does not clarify why the exception process was not followed. Requires validation from KDB management.

Proposed Corrective Action Owner: GRC Co-Lead — the role assigned as accountable for Exception Approval in the Governance Charter's Decision Rights table and the reviewing party at Stage 3.

Proposed Completion / Follow-Up Action: No completion timeframe is established in the audit criteria or KDB source documents; thus, none is proposed here. KDB management should determine an appropriate completion target.

Expected Evidence of Completion: A documented review record addressing the two identified deviations and evidence that an exception-logging step exists and is applied for the Stage 3 review moving forward.

Verification / Closure Approach: A follow-up sample of escalation records, beyond the original eight, to confirm that no further undocumented Stage 3 deviations exist and that the two identified instances have been reviewed and closed.

NC-02 – A.5.9, Inventory of Information and other Associated Assets

Confirmed Nonconformity Addressed: Two asset records lacked the required classification information.

Recommended Corrective Action: Classify the two identified assets. Review whether classification is consistently applied at the point of creation or acquisition for assets added during infrastructure expansion, given that the identified gaps coincide with a specific expansion event.

Root Cause / Contributing Factor: The evidence supports one contributing observation: the unclassified assets coincide with a discrete provisioning event (backup storage volumes added during the Q1 2026 DR expansion), suggesting that classification may not always be applied consistently during expansion-driven provisioning. This observation serves as a contributing factor visible in the evidence, but it is not confirmed as the root cause; the underlying reason is not established and requires KDB management validation.

Proposed Corrective Action Owner: The SoA names the “IT Asset Manager” as the A.5.9 control owner. However, KDB’s actual Asset Management Policy (Task 9) assigns classification accuracy to the Asset Owner and centralized register maintenance to the IT Security Manager; no equivalence between these roles is assumed. The recommended owner, per the more specific and directly applicable Task 9 policy, is the Asset Owner, supported by the IT Security Manager.

Proposed Completion / Follow-Up Action: No deadline is proposed; none is established in the source documents.

Expected Evidence of Completion: An updated asset register/CMDB export showing classification populated for the two identified assets, along with confirmation that classification is embedded as a step in the asset provisioning process.

Verification / Closure Approach: Re-sample the asset register, including assets added since the original sample, in a follow-up review to confirm classification completeness.

NC-03 – A.5.15, Access Control

Confirmed Nonconformity Addressed: Two of fifteen sampled de-provisioning tickets breached the Task 9 §3.2 24-hour revocation requirement by five and seven days, respectively, with no documented exception. Both breaches are tied to a single May 2026 system migration window.

Recommended Corrective Action: Formally review and document the circumstances of the two identified de-provisioning delays, including whether the applicable Task 9 §3.2 exception and escalation process should have been followed at the time. Ensure that future missed de-provisioning timeframes are recorded through the applicable exception and escalation process, including CISO escalation where required by Task 9 §3.2. Additionally, review whether de-provisioning during system migration events warrants a specific operational safeguard, given that both breaches can be traced to the same migration window.

Root Cause / Contributing Factor: The evidence supports one contributing observation: both breaches occurred during the same migration event, suggesting that migration-related operational conditions may have affected timeliness. This inference stems from a shared timing pattern, not a confirmed cause; a deeper reason is not established and requires KDB management validation.

Proposed Corrective Action Owner: The SoA names the “IAM Lead” as the A.5.15 control owner. Yet, Task 9’s actual Access Control Policy assigns accountability for de-provisioning and timeframe compliance to the IT Security Manager; no equivalence between the “IAM Lead” and “IT Security Manager” is assumed. The recommended owner, per the Task 9 policy, is the IT Security Manager.

Proposed Completion / Follow-Up Action: No deadline is proposed.

Expected Evidence of Completion: A documented review record addressing the two identified instances; evidence of the applicable Task 9 §3.2 exception/escalation process being followed; any resulting review notes on de-provisioning during migration events.

Verification / Closure Approach: Sample de-provisioning tickets in a follow-up review, including any tied to future migration or similar bulk-change events, to confirm timeliness and compliance with exception documentation.

NC-04 – A.6.1, Screening

Confirmed Nonconformity Addressed: Background verification records were missing for 2 out of 10 sampled new hires.

Recommended Corrective Action: Obtain and file background verification records, or documented third-party screening confirmations, for the two identified individuals.

Root Cause / Contributing Factor: Not established by the available evidence. The evidence confirms the absence of records but does not clarify why. This requires validation from KDB management.

Proposed Corrective Action Owner: HR Manager — designated owner for A.6.1 per the Statement of Applicability (SoA). There is no competing role vocabulary to reconcile for this item, as no Task 9 policy addresses screening.

Proposed Completion / Follow-Up Action: No deadline is proposed.

Expected Evidence of Completion: Completed background verification records or vendor confirmations on file for both individuals.

Verification / Closure Approach: Re-sample new-hire records in a follow-up review to confirm that records are filed for the tested population.

NC-05 – A.6.8, Information Security Event Reporting

Confirmed Nonconformity Addressed: One of 12 sampled medium-severity events was escalated 30 hours after detection, breaching the Task 9 §3.2 24-hour requirement by 6 hours, with no documented exception.

Recommended Corrective Action: Formally review and document the circumstances surrounding the identified escalation delay, including whether the applicable Task 9 §3.2 exception process should have been followed. Ensure future missed escalation timeframes are recorded through the applicable exception process when they occur. The extent of any broader process improvement should be determined by KDB management based on its review of the identified instance and any validated root cause.

Root Cause / Contributing Factor: Not established by the available evidence—this is a single isolated instance with no observable pattern in the sample. This requires validation from KDB management.

Proposed Corrective Action Owner: The Statement of Applicability names the "SOC Manager" as the owner for A.6.8. However, Task 9's Incident Reporting Policy assigns accountability for triage, severity determination, and timeframe compliance to the Incident Response Lead; no equivalence is assumed. The recommended owner, according to the applicable Task 9 policy, is the Incident Response Lead.

Proposed Completion / Follow-Up Action: No deadline is proposed.

Expected Evidence of Completion: A documented review record addressing the identified instance.

Verification / Closure Approach: Sample future incident escalation records in a follow-up review to confirm compliance with timeliness and exception documentation.

NC-06 – A.8.24, Use of Cryptography

Confirmed Nonconformity Addressed: No cryptographic/key-management standard document exists within KDB's artifact set. However, the underlying encryption control (TLS, cloud encryption-at-rest) is evidenced as implemented and operational.

Recommended Corrective Action: Develop and formally approve documented rules for the effective use of cryptography and cryptographic key management, including the applicable encryption and key-management requirements for data in transit and at rest, consistent with the encryption controls already evidenced.

Root Cause / Contributing Factor: The immediate cause is clearly evidenced: no cryptographic/key-management standard has been developed as part of KDB's policy suite (Task 9's five existing policies do not address cryptography). The underlying reason for the absence of this document is not established and requires validation from KDB management.

Proposed Corrective Action Owner: Security Architecture Lead — the individual designated per the Statement of Applicability for A.8.24 to draft the standard. The approval authority is flagged as an open governance question rather than being assumed: while the Policy Hierarchy would assign Standard-tier approval to the GRC Lead, Task 9's actual policies are uniformly approved by “CISO”, a role that remains undefined in the Governance Charter. This unresolved conflict has already been documented against Clause 7.5 in the Findings Register. The recommendation does not resolve this conflict; KDB should determine the correct approval authority for this new document as part of addressing it.

Proposed Completion / Follow-Up Action: No deadline is proposed.

Expected Evidence of Completion: An approved cryptographic/key-management standard document, including version, owner, and approval record on file.

Verification / Closure Approach: Confirm in a follow-up review that the standard document exists, is approved by the authority KDB determines is applicable, and that current TLS and cloud encryption practices align with it.

Note — Evidence Limitation, Not Part of This Corrective Action: The status of on-premises database encryption-at-rest remains unevidenced in the Phase 3 assessment. This is recorded as an existing evidence limitation on the underlying finding (F-25 / NC-06), not as a confirmed control failure, and is not included in the corrective action above. Obtaining evidence of on-premises encryption-at-rest configuration would resolve this limitation, but it is a separate matter from developing the cryptographic/key-management standard.

3. Items Excluded from Corrective Action

Consistent with the audit's evidence-first methodology, the following items are not addressed by corrective action recommendations in this document, as they are not confirmed nonconformities: the eight fully Pending items (Clause 6.1.3, Clause 7.5, A.5.19, A.6.3, A.7.7, A.8.8, A.8.9, A.8.13), the Pending HR-notification component of A.6.5, and Clause 8.1 (concluded as Conforming, with documented evidence limitations). These remain open items as recorded in the Findings Register and are outside the scope of this corrective action deliverable.

- End of Report -